

Protection des Jetons d'Accès Utilisateur — API Meta (Facebook Login)

Politique décrivant comment BantuDelice protège les jetons d'accès Meta contre tout accès non autorisé, conformément aux exigences de la Politique de développement Meta et aux standards de sécurité des API.

1. MÉCANISMES DE PROTECTION APPLIQUÉS

BantuDelice applique deux mécanismes combinés pour protéger les jetons d'accès Meta :

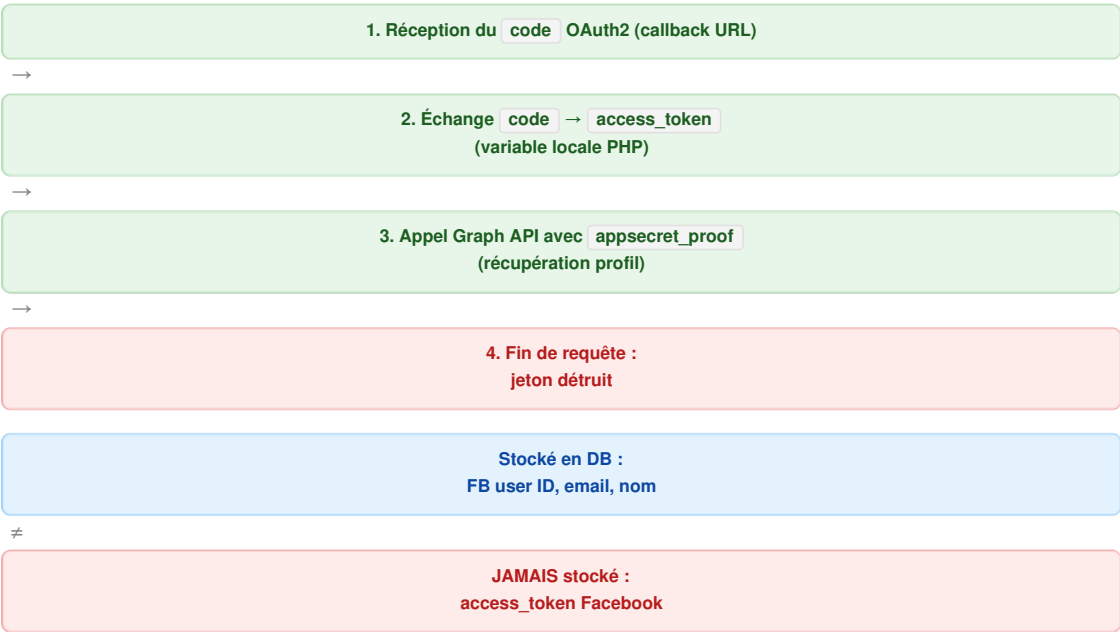
#	Mécanisme	Appliqué
A	Coffre-fort de données (HashiCorp Vault) avec KMS distinct	Non applicable
B	Chiffrement applicatif — les jetons ne sont jamais écrits en clair en base de données ni dans tout autre stockage persistant	✓ OUI
C	Paramètre appsecret_proof requis pour tous les appels API Meta	✓ OUI
D	Approche différente	—

2. PROTECTION DES JETONS CONTRE LA LECTURE NON AUTORISÉE

★ CONDITION REQUISE META — SURLIGNÉE

Les jetons d'accès Facebook sont éphémères et strictement en mémoire : ils ne sont jamais écrits en base de données, en cache persistant, dans des fichiers ou dans tout autre stockage. Après validation de l'identité de l'utilisateur via l'API Graph, le jeton est immédiatement abandonné (hors de portée) et ne peut plus être lu.

2.1 Cycle de vie d'un jeton d'accès Facebook dans l'application



2.2 Ce qui est stocké en base de données

Donnée	Stockée	Format	Table
--------	---------	--------	-------

Donnée	Stockée	Format	Table
Jeton d'accès Facebook (<code>access_token</code>)	X JAMAIS	—	—
ID utilisateur Facebook (<code>provider_id</code>)	✓ Oui	Chaîne numérique	<code>users.social_id</code>
Adresse email	✓ Oui	Texte chiffré en transit	<code>users.email</code>
Nom d'affichage	✓ Oui	Texte	<code>users.name</code>
URL avatar (publique)	✓ Oui	URL HTTPS	<code>users.social_avatar</code>
Token API BantuDelice	✓ Oui	SHA-256 haché (non réversible)	<code>users.api_token</code>

Note : Le token API BantuDelice est un token interne généré aléatoirement (60 caractères) puis haché en SHA-256 avant stockage. Il n'est pas un jeton d'accès Meta.

2.3 Paramètre `appsecret_proof` — Protection contre le vol de token

Tous les appels à l'API Graph Meta utilisent le paramètre `appsecret_proof` : un HMAC-SHA256 du jeton d'accès signé avec le secret d'application (`FACEBOOK_CLIENT_SECRET`). Cela garantit qu'un jeton intercepté ne peut pas être utilisé sans posséder également le secret d'application, qui est stocké exclusivement dans le fichier `.env` du serveur (jamais dans le dépôt Git).

```
// SocialAuthService.php — appels Graph API Facebook
$appSecret = config('external-services.social_auth.facebook.client_secret', '');
$appsecretProof = hash_hmac('sha256', $accessToken, $appSecret);

Http::get('https://graph.facebook.com/me', [
    'access_token' => $accessToken,
    'appsecret_proof' => $appsecretProof, // HMAC-SHA256 requis
    'fields' => 'id,name,email,picture.type(large)',
]);
```

3. INTERDICTION D'ÉCRITURE DES JETONS DANS LES FICHIERS JOURNAUX

★ CONDITION REQUISE META — SURLIGNÉE

Les jetons d'accès utilisateur Meta ne sont jamais écrits dans les fichiers journaux (logs) sous forme de texte clair. Cette règle est mise en œuvre par conception dans le code de l'application et documentée comme exigence obligatoire pour tout développeur contribuant à la base de code.

3.1 Politique de logging — Règles explicites

- **Interdit** : Logger tout objet contenant un `access_token`, `token`, `refresh_token` ou `appsecret_proof` en clair.
- **Interdit** : Logger les réponses brutes des appels `oauth/access_token` sans masquage préalable.
- **Autorisé** : Logger les métadonnées non sensibles : `user_id`, `provider`, `timestamp`, codes d'erreur HTTP.

3.2 Implémentation dans le code

Vérification des deux seuls points de logging dans le flux Facebook Login :

Appel Log	Contenu loggé	Jeton inclus ?
<code>Log::error('Facebook token exchange failed')</code>	Réponse d'erreur de l'échange de code — à ce stade, aucun access_token n'existe (l'échange a échoué)	✗ Non
<code>Log::info('Nouvel utilisateur créé via social auth')</code>	<code>['user_id' => \$user->id, 'provider' => 'facebook']</code>	✗ Non

```
// Seul log en cas de succès — aucun token présent
Log::info('Nouvel utilisateur créé via social auth', [
    'user_id' => $user->id, // ID interne BantuDelice uniquement
    'provider' => $data['provider'], // 'facebook' — aucun token
]);
// Le $accessToken Facebook n'est JAMAIS passé à Log::*
```

3.3 Configuration des logs Laravel

Paramètre	Valeur en production	Effet
<code>LOG_CHANNEL</code>	<code>daily</code>	Rotation quotidienne, rétention 14 jours
<code>LOG_LEVEL</code>	<code>warning</code>	Seuls warning/error/critical sont loggés — pas de debug verbose
<code>APP_DEBUG</code>	<code>false</code>	Aucune stack trace avec données sensibles exposée en production

4. MESURES COMPLÉMENTAIRES DE PROTECTION

Mesure	Implémentation
Chiffrement en transit	HTTPS TLS 1.2+ obligatoire sur tous les endpoints. Les jetons ne transitent jamais en clair sur le réseau.
Secret d'application Facebook	Stocké exclusivement dans <code>.env</code> sur le serveur. Absent du dépôt Git (vérifié par <code>.gitignore</code> et audit Git).
Variables d'environnement	<code>FACEBOOK_CLIENT_SECRET</code> accessible uniquement par le processus PHP/Nginx (<code>www-data</code>). Permissions fichier <code>640</code> .
Accès base de données	Connexion MySQL restreinte à <code>localhost</code> . Mot de passe lu depuis <code>.env</code> uniquement (jamais en clair dans le code).
Durée de vie de la session	Session BantuDelice indépendante du token Facebook. Expiration configurable. Le token Facebook n'est pas recréé en session.
Endpoint de suppression des données	Endpoint <code>/facebook/data-deletion</code> actif — supprime toutes les données liées au Facebook user ID sur demande Meta.

5. DÉCLARATION DE CONFORMITÉ

BantuDelice déclare que :

- Aucun jeton d'accès Meta (Facebook) n'est stocké en base de données, en cache, dans des fichiers ou dans tout autre stockage persistant.
- Aucun jeton d'accès Meta n'est écrit dans les fichiers journaux de l'application, que ce soit en clair ou sous forme encodée.
- Le paramètre `appsecret_proof` est utilisé sur tous les appels à l'API Graph Facebook.

- Le secret d'application (`FACEBOOK_CLIENT_SECRET`) est protégé et n'est jamais exposé dans le code source ou les logs.
-

Responsable technique — BantuDelice

Date : 3 juin 2026

Référence : BDL-META-TOKEN-POLICY-2026
bantudelice.cg | gess198@gmail.com
Brazzaville, République du Congo